

Static Analysis

Perform Analysis Procedure

Revision

Version 4
4/6/26 7:33 PM

SME

Charles Wilson

Abstract

This document describes the procedure used to perform the **perform analysis** activity described in the **AVCDL** ^[1] secondary document **Static Analysis Report** ^[2].

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to have early cybersecurity-related implementation feedback in the development of software for use within safety-critical, cyber-physical systems.

Note: Within the context of this document, the terms **security** and **cybersecurity** are used interchangeably. It is presumed that the term **security** is being used in reference to **cybersecurity** and not **physical security**.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Audience

The audience of this document is the cybersecurity practitioner who will be conducting cybersecurity-specific static analysis.

Completeness of Output

Since static analysis is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the cybersecurity SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

Disposition of Output

This activity does not produce documentation as an output.

Entry Criteria

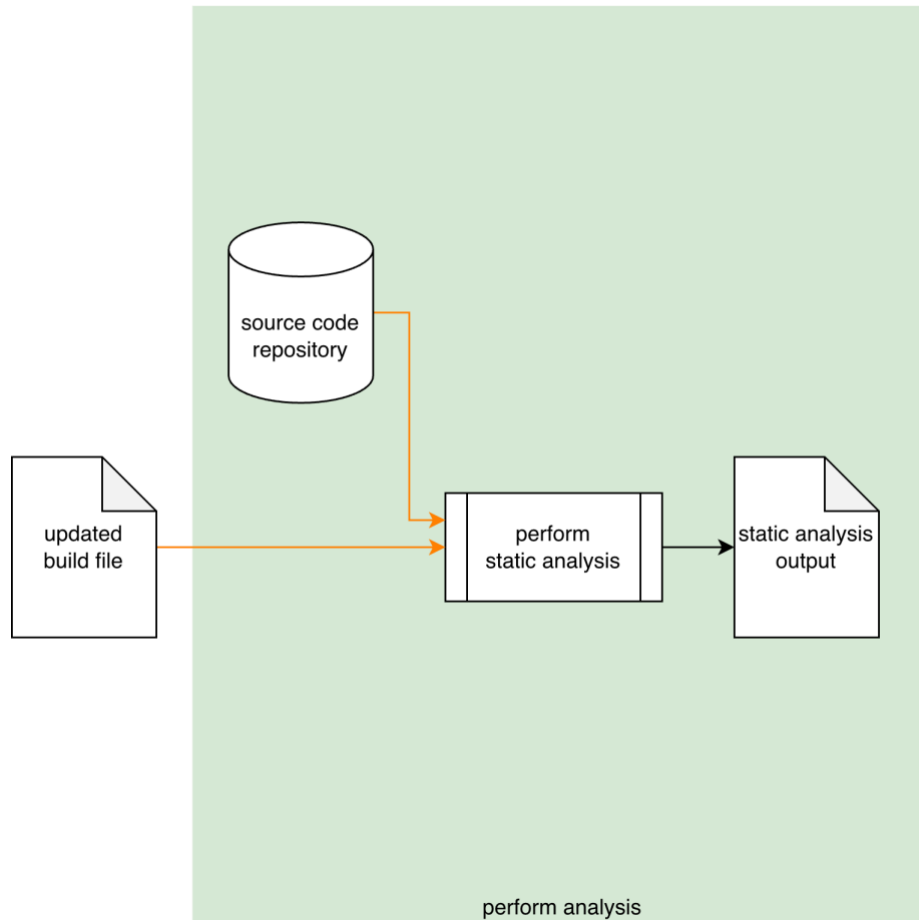
This document assumes that the reader understands the purpose of cybersecurity-specific static analysis. Further, that the reader has read and understood the AVCDL **Static Analysis Report** secondary document.

Prerequisites – Input Materials

It is required that the build file has been updated as a result of the static analysis settings establishment activity. It is further required that the static analysis tool have the access within the source code repository necessary to complete the procedure.

Perform Analysis Activity

The workflow diagram for the **perform analysis** activity of the **Static Analysis** process is shown below.



Drawing on the **Source Code Repository** and using the settings specified in the **Updated Build File**, the **Static Analysis** tool performs a cybersecurity-focused static analysis of the element under consideration. The generated output is captured into a **Static Analysis Output** file.

Note: As shown above, this activity is presumed to be performed within the CI/CD pipeline, and as such requires no participation by people.

Note: Where possible, it is recommended that the static analysis output be a SARIF ^[5] encoded JSON file.

Methodology

If the preceding activity of establishing the settings has been properly followed, this activity should just work. Its inclusion should therefore be simply to provide completeness to the static analysis process. Any issues which arise should fall into one of the categories covered in the next section.

Considerations

The following items were introduced in the **Considerations** section of the **Static Analysis Establish Settings Procedure** ^[3] document. We come back to them because although they should have been addressed during the **Secure Settings - Apply Options** ^[4] activity and the pre-flight of the test within the CI/CD system, these may still need to be addressed within the context of the live CI/CD process.

Option Interaction

Options are not always isolated from each other. This is especially true when dealing with compiler options. If static analysis is producing results that do not align with the introduced cybersecurity options, the options should be reviewed to confirm their applicability.

Execution Impact

Static analysis is a resource intensive activity. Ensure that sufficient resources (time, memory, storage) are available.

Over time, the scope of the analysis activity will likely consume more resources. Be sure to monitor the time required for the activity to complete.

Also, since standalone static analysis tools are typically database backed and maintain historical data, the storage for the static analysis database should be reviewed in order to ensure that it is sufficient.

Note: There may be the desire to enable cybersecurity-relevant settings for non-static analysis tools directly in order to provide direct developer feedback. This should be avoided until the scale of the issues is understood.

Exit Criteria

This procedure is considered complete once the **Static Analysis Output** has been generated.

References

1. **AVCDL** (AVCDL primary document)
2. **Static Analysis Report** (AVCDL secondary document)
3. **Static Analysis Establish Settings Procedure** (AVCDL tertiary document)
4. **Secure Settings - Apply Options Procedure** (AVCDL tertiary document)
5. **Static Analysis Results Interchange Format (SARIF) Version 2.1.0**
<https://docs.oasis-open.org/sarif/sarif/v2.1.0/os/sarif-v2.1.0-os.pdf>